

דוח מחקר

אבטחת המרחב המקוון

מגישה: יפית ברנר

Yafit.bre@gmail.com

ניתוח מנגנוני אבטחה ואימות

השוואת ביצועים, עמידות בפני תקיפות ומנגנוני הגנה

מטרת המחקר

- הדגמת הפער הדרמטי בין פונקציות גיבוב מהירות SHA256 ל-Argon2id
- בדיקת אלגוריתמים מול מתקפות Brute Force & Password Spraying
- יעילות הגנות ומדידת האפקטיביות של:
 - Rate Limit
 - Account Lockout
 - CAPTCHA
 - TOTP
- הסקת מסקנות לגבי ארכיטקטורת אימות מאובטחת.

ארכיטקטורת המערכת

- המערכת מדמה סביבת שרת לקוח באמצעות REST API
- Auth_Server.py מבוסס Python Flask
- JSON DB
- משתמשים: מאגר הכולל 3 קבוצות:
סיסמאות חלשות, בינוניות וחזקות עם TOTP
- config*.json קבצי קונפיגורציה של הגדרות האבטחה
כלומר אלגוריתמי גיבוב או נעילה.
- התוקף : Attacker.py
- סקריפט אוטומטי חכם שמבצע ניסיונות פריצה עם מילון rockyou.txt ומגיב לקודי שגיאה מהשרת.

ביצועים מול אבטחה:

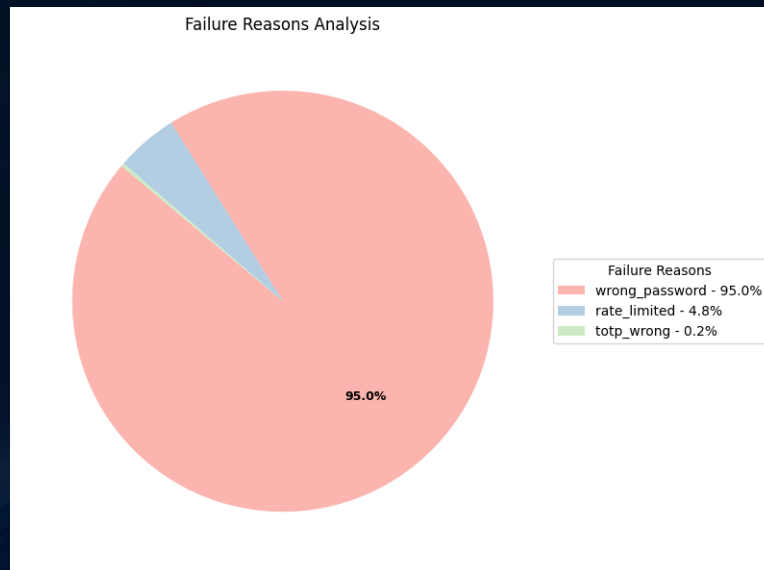
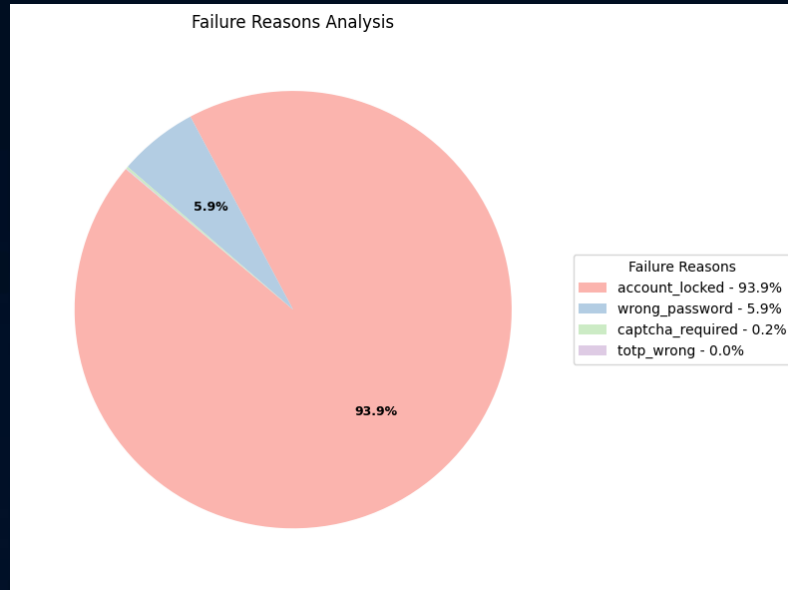
- אלגוריתמי גיבוב
- SHA256 מהיר
- Bcrypt איטי ודורש הרבה משאבים.
- Argon2id מבוסס ועמיד בפני תוקפים.
- וקטורי תקיפה:
- Brute Force תקיפה ממוקדת על משתמש בודד.
- Password Spraying תקיפה של סיסמה אחת על משתמשים רבים לעקיפת מנגנוני נעילה.

CAPTCHA

- שומר כניסה כלומר הוא חוסם בוטים לפני הגישה לבסיס הנתונים.
- חיסכון במשאבים: מניעת עומס חישובי על השרת (מניעת DOS)
- חויית משתמש: מניעת נעילות בגלל טעויות הקלדה.

Lockout

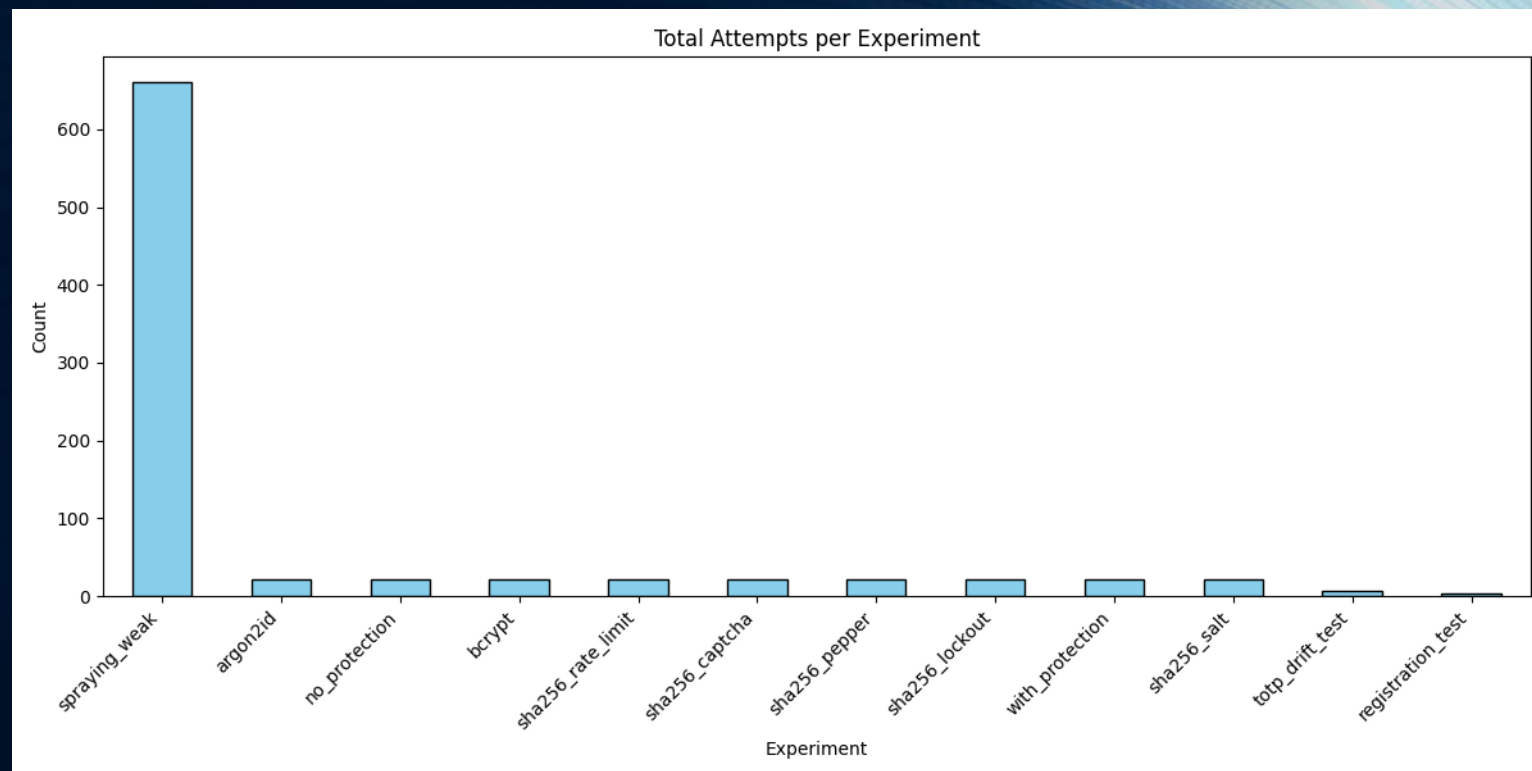
התוקף נחסם לאחר 5 ניסיונות בלבד.
אז המסקנה היא מנגנון נעילה הוא
קריטי לעצירת
Brute Force



- סיסמאות חלשות נפרצו גם עם Rate Limit פעיל.
- הפתרון הוא TOTP, אימות דו שלבי להורדת אחוזי הפריצה ל-0%
- מנגנון Drift סנכרון של 90ms למניעת חסימת משתמשים לגיטימיים.

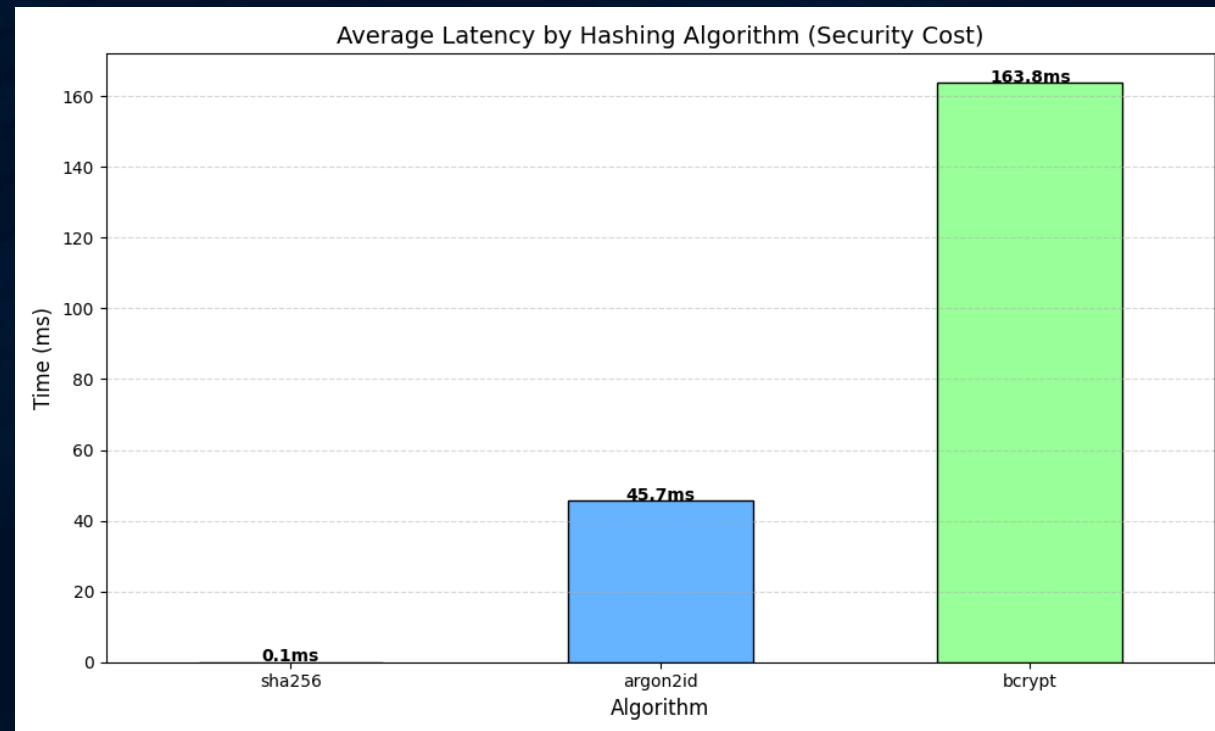
יעילות מנגנוני ההגנה

תקיפת SPRAYING ביצעה
מאות ניסיונות בזמן קצר עם
עקיפת מנגנון הנעילה
הבודד.

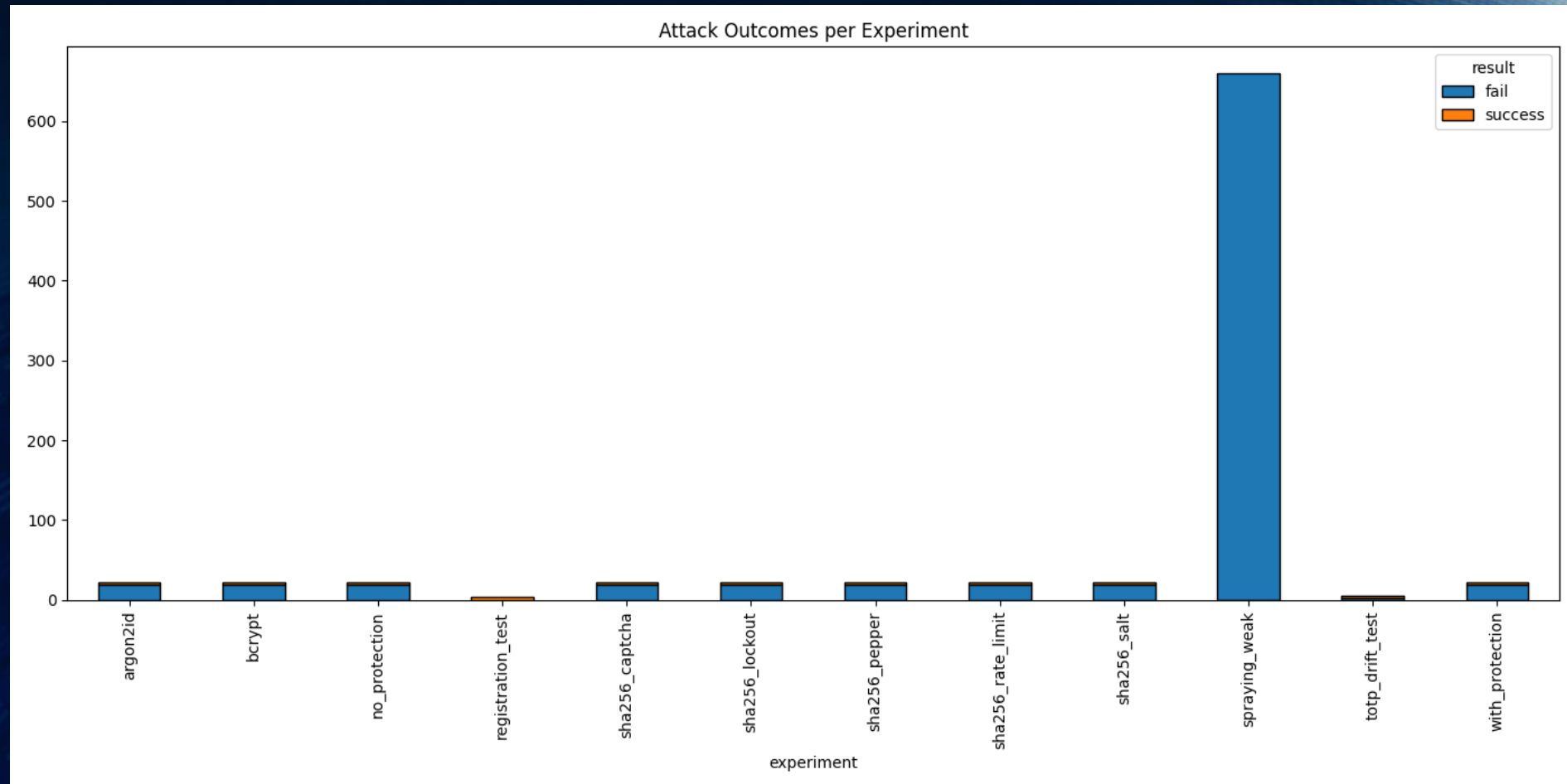


ביצועים מול אבטחה

- **SHA256 0.0ms** מהיר מדי שמאפשר סריקת מילונים מיידית (לא מאובטח).
- **Bcrypt 164ms** אבטחה חזקה אבל יקר במשאבים וסיכון ל DOS
- **Argon2id 46ms** האופטימלי בין אבטחה לביצועים.

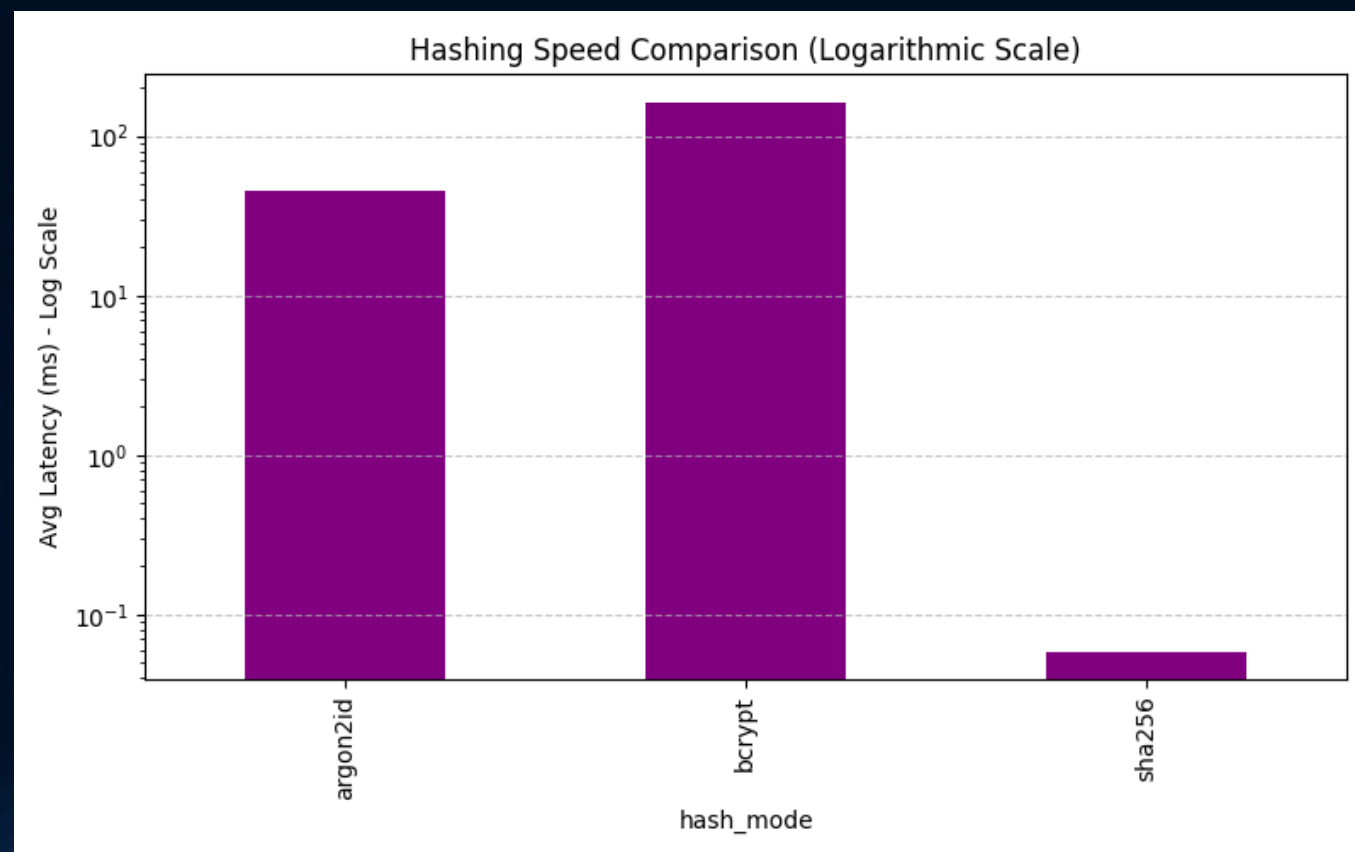


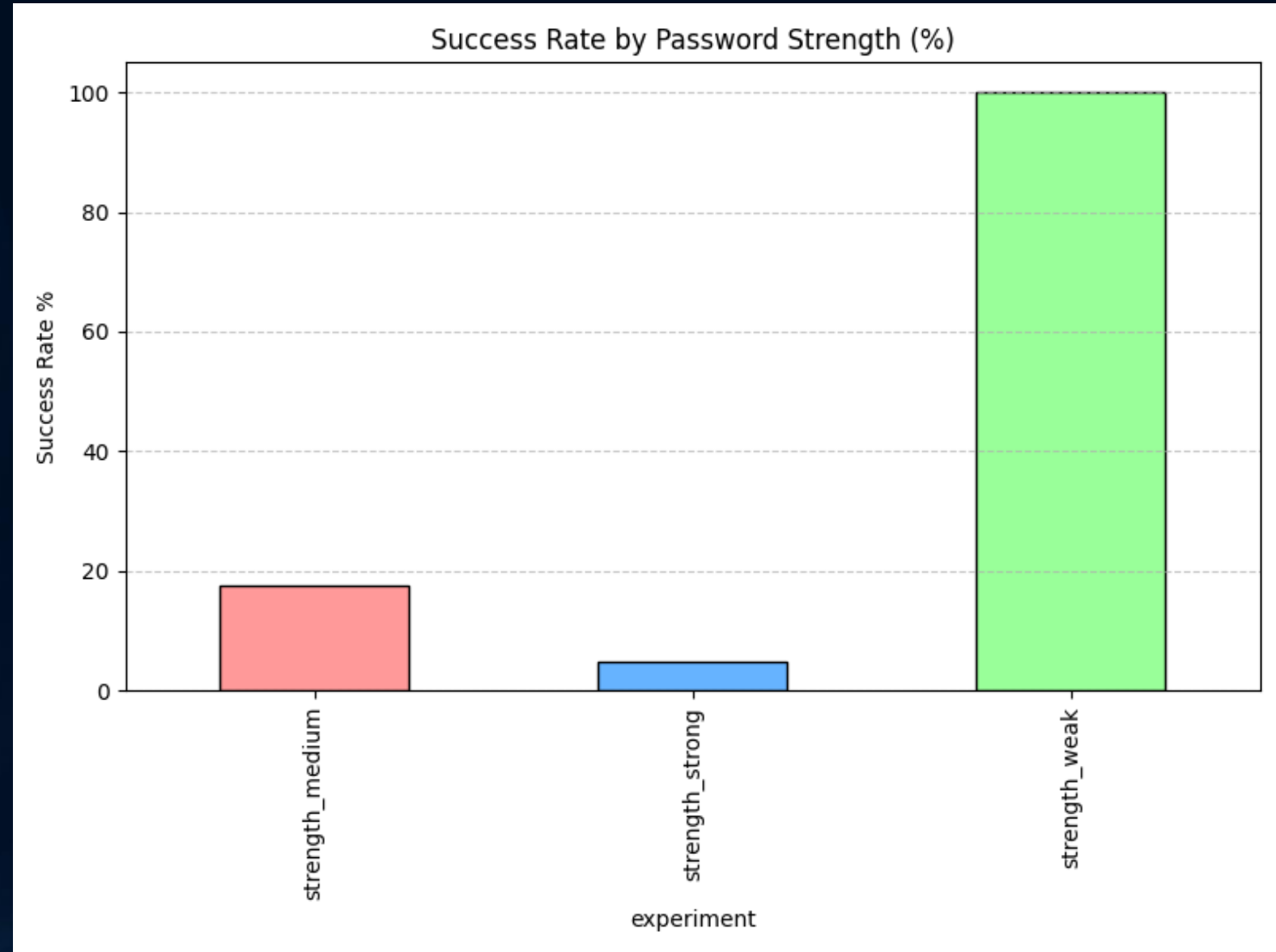
- Brute Force תקיפה ממוקדת על משתמש בודד.
- Password Spraying תקיפה של סיסמה אחת על משתמשים רבים לעקיפת מגנוני נעילה

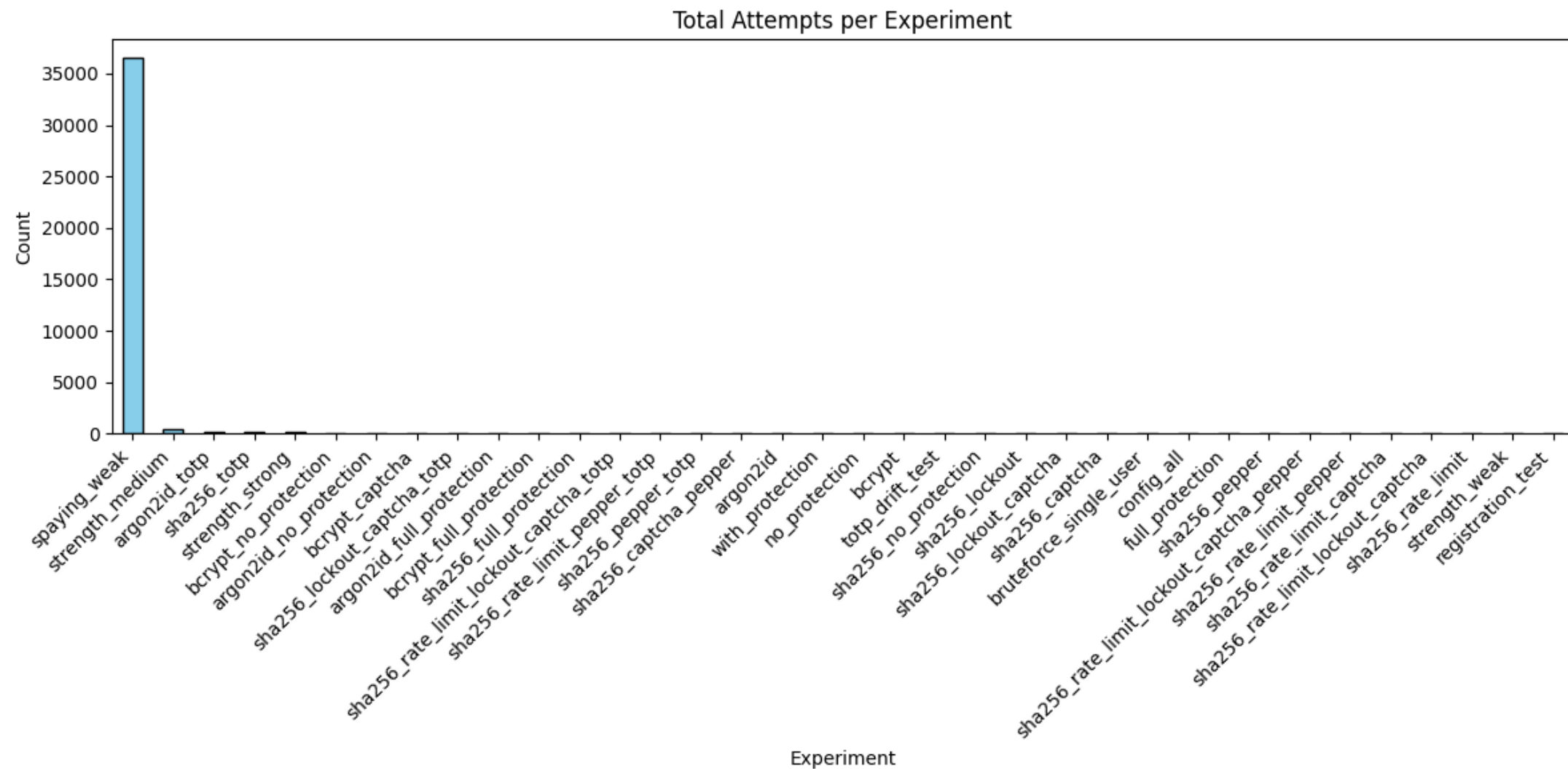


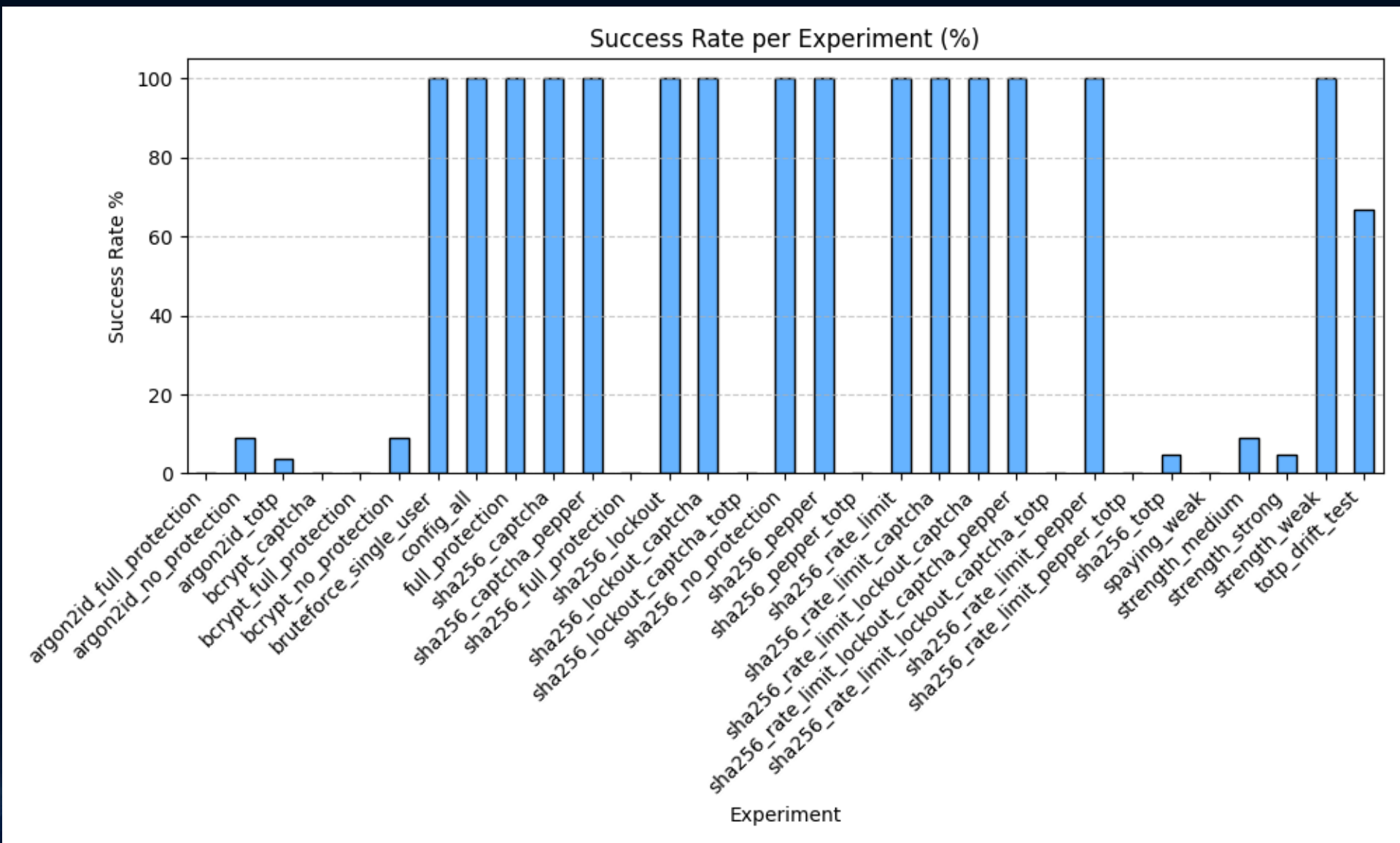
• אלגוריתמי גיבוב:

SHA-256 מהיר
Bcrypt איטי ודורש הרבה משאבים.
Argon2id מבוסס ועמיד בפני תוקפים.

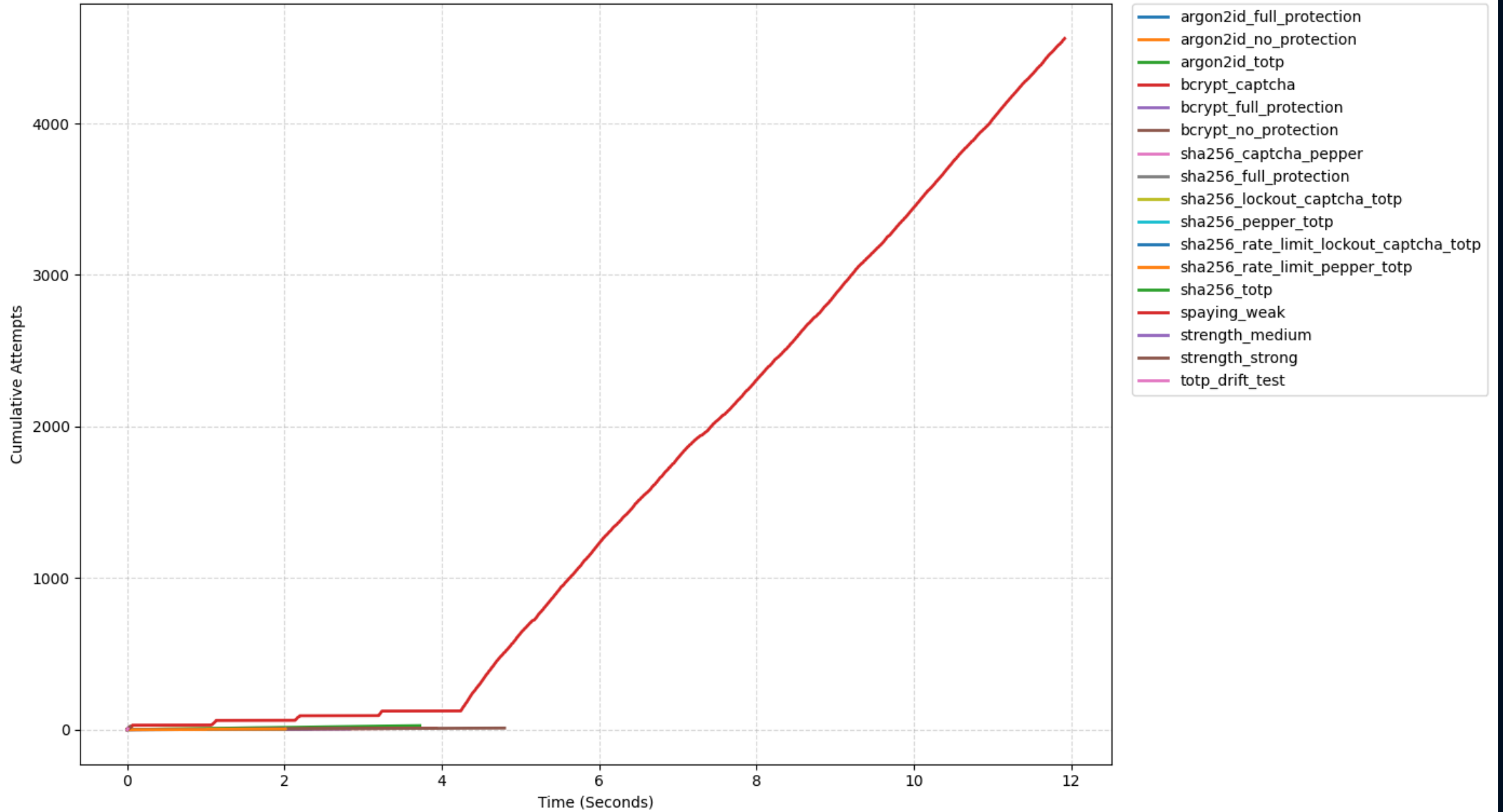




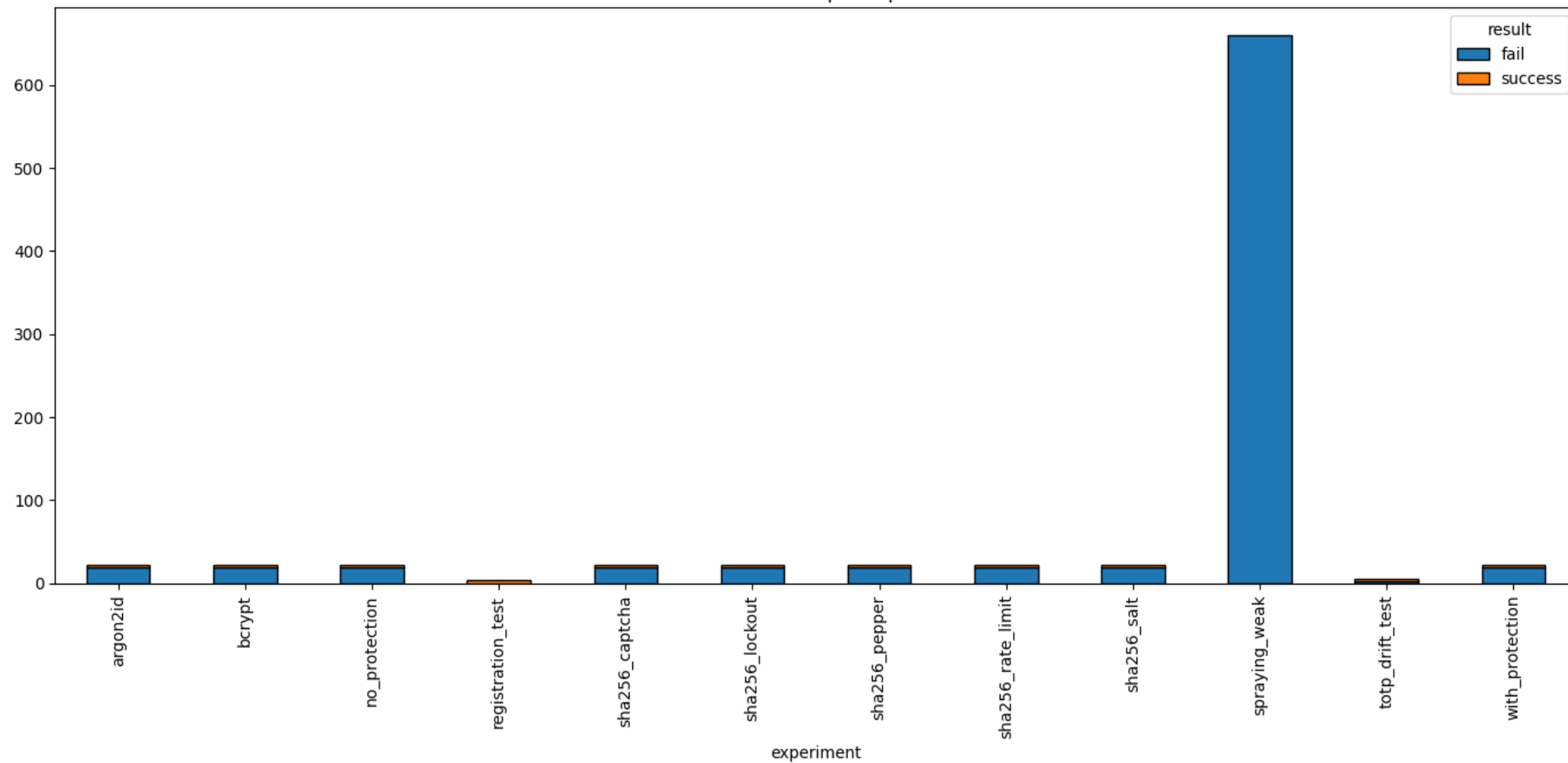




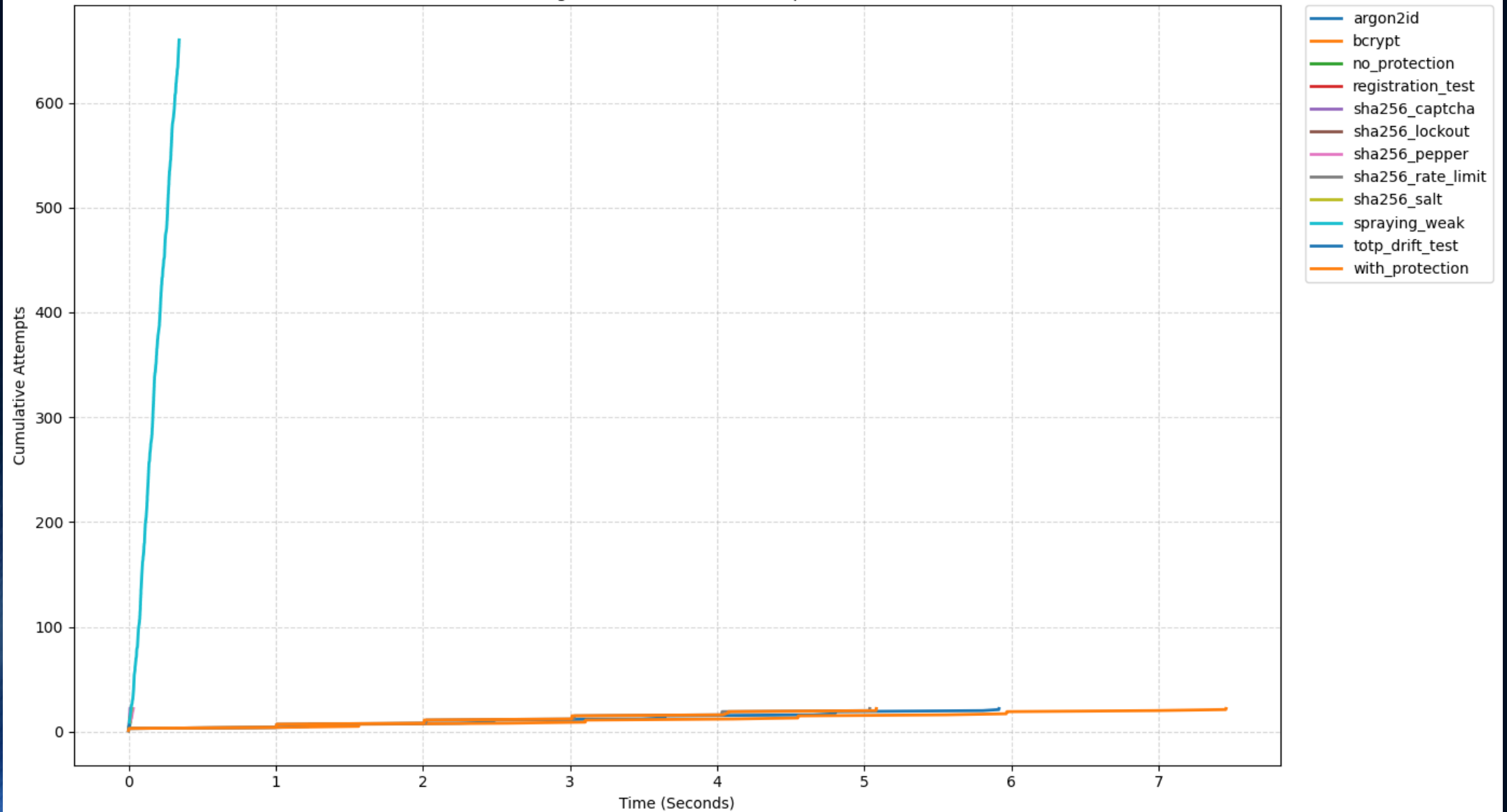
Attack Progression Over Time (All Experiments)



Attack Outcomes per Experiment



Attack Progression Over Time (All Experiments)



סיכום ומסקנות

1. המלצה טכנולוגית: מעבר ל-Argon2id
2. חובה: הטמעת מנגנון Account Lockout
3. מדיניות: טכנולוגיה חובה וגם אכיפה של סיסמאות חזקות.
4. ארכיטקטורה: הגנה משולבת:
TOTP + CAPTCHA + Rate Limit + Hash

אתיקה

סביבת Sandboc בדיקות מקומית ומבודדת ללא גישה לרשת.

שימוש בנתונים לא אמיתיים וללא מידע אישי.

שימוש ב group_seed קבוע - ת.ז 123456789

מצ"ב נספחים:

• 3 וידאו

• צילומי מסך של 2 הרצות שונות.

• לוגים

• גרפים

• HTML

• דוח מחקר

Run 1

For a complete run from scratch, execute these commands in order:

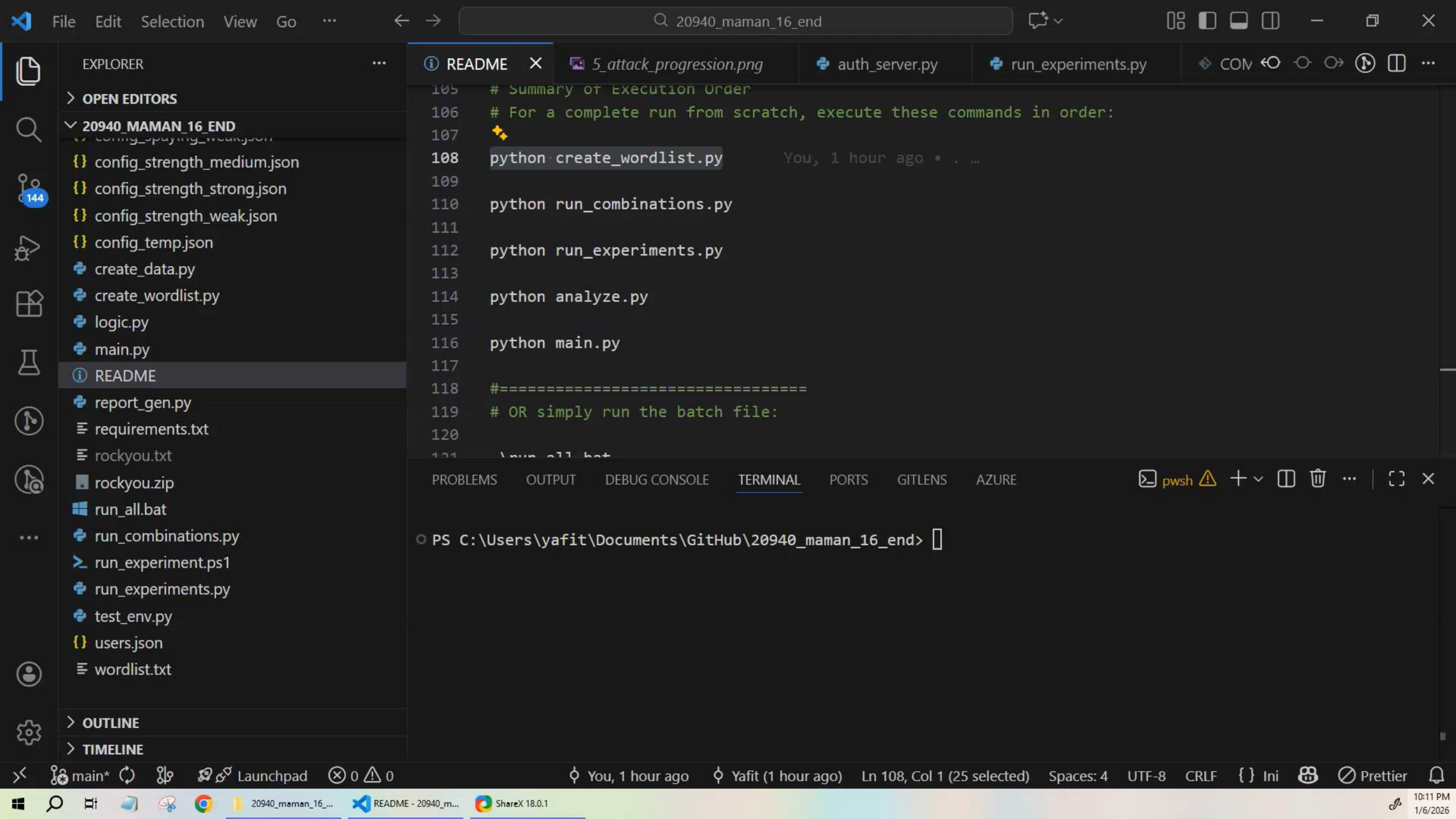
```
python create_wordlist.py
```

```
python run_combinations.py
```

```
python run_experiments.py
```

```
python analyze.py
```

```
python main.py
```



```
File Edit Selection View Go ... 20940_maman_16_end
```

EXPLORER

> OPEN EDITORS

20940_MAMAN_16_END

- config_strength_medium.json
- config_strength_strong.json
- config_strength_weak.json
- config_temp.json
- create_data.py
- create_wordlist.py
- logic.py
- main.py
- README
- report_gen.py
- requirements.txt
- rockyou.txt
- rockyou.zip
- run_all.bat
- run_combinations.py
- run_experiment.ps1
- run_experiments.py
- test_env.py
- users.json
- wordlist.txt

> OUTLINE

> TIMELINE

README

```
105 # Summary of Execution Order
106 # For a complete run from scratch, execute these commands in order:
107
108 python create_wordlist.py
109
110 python run_combinations.py
111
112 python run_experiments.py
113
114 python analyze.py
115
116 python main.py
117
118 #=====
119 # OR simply run the batch file:
120
121 \run_all.bat
```

PROBLEMS OUTPUT DEBUG CONSOLE TERMINAL PORTS GITLENS AZURE

PS C:\Users\yafit\Documents\GitHub\20940_maman_16_end>

main* 0 0 You, 1 hour ago Yafit (1 hour ago) Ln 108, Col 1 (25 selected) Spaces: 4 UTF-8 CRLF {} Ini Prettier

20940_maman_16_... README - 20940_m... ShareX 18.0.1

10:11 PM 1/6/2026

FileEditSelectionViewGo

20940_maman_16_end

7_defense_effectiveness.pngauth_server.pyrun_experiments.py

EXPLORER

OPEN EDITORS

20940_MAMAN_16_END

config_spaying_weak.json

config_strength_medium.json

config_strength_strong.json

config_strength_weak.json

config_temp.json

create_data.py

create_wordlist.py

logic.py

main.py

README

report_gen.py

requirements.txt

rockyou.txt

rockyou.zip

run_all.bat

run_combinations.py

run_experiment.ps1

run_experiments.py

test_env.py

users.json

wordlist.txt

OUTLINE

TIMELINE

101

102python main.py

103

104

PROBLEMS

OUTPUT

DEBUG CONSOLE

TERMINAL

PORTS

GITLENS

AZURE

pwsh

PS C:\Users\yafit\Documents\GitHub\20940_maman_16_end> & C:/Users/yafit/Documents/GitHub/20940_maman_16_end/.venv/Scripts/Activate.ps1

(.venv) PS C:\Users\yafit\Documents\GitHub\20940_maman_16_end>

PS C:\Users\yafit\Documents\GitHub\20940_maman_16_end> & C:/Users/yafit/Documents/GitHub/20940_maman_16_end/.venv/Scripts/Activate.ps1

PS C:\Users\yafit\Documents\GitHub\20940_maman_16_end> & C:/Users/yafit/Documents/GitHub/20940_maman_16_end/.venv/Scripts/Activate.ps1

PS C:\Users\yafit\Documents\GitHub\20940_maman_16_end> python create_wordlist.py

[+] Successfully created 'common_passwords.txt' with 11 entries.

(.venv) PS C:\Users\yafit\Documents\GitHub\20940_maman_16_end> python run_combinations.py

--- Starting Security Mechanism Analysis (Combinations) ---

=== Running experiment: sha256_salt ===

[*] Launching attacker for sha256_salt...

[Brute-Force] Attacking user: user11

[+] Password found for user11: Password11!

[+] Experiment sha256_salt completed.

=== Running experiment: sha256_pepper ===

[*] Launching attacker for sha256_pepper...

[Brute-Force] Attacking user: user11

[+] Password found for user11: Password11!

[+] Experiment sha256_pepper completed.

<main*Launchpad00

You, 2 hours agoYafit (2 hours ago)

Ln 110, Col 1 (26 selected)Spaces: 4UTF-8CRLF{ } IniPrettier

FileEditSelectionViewGo

20940_maman_16_end

EXPLORER

OPEN EDITORS

20940_MAMAN_16_END

config_sha256_lockout.json

config_spaying_weak.json

config_strength_medium.json

config_strength_strong.json

config_strength_weak.json

config_temp.json

create_data.py

create_wordlist.py

logic.py

main.py

README

report_gen.py

requirements.txt

rockyou.txt

rockyou.zip

run_all.bat

run_combinations.py

run_experiment.ps1

run_experiments.py

test_env.py

users.json

wordlist.txt

OUTLINE

TIMELINE

7_defense_effectiveness.png

auth_server.py

run_experiments.py

101

102 python main.py

103

104

PROBLEMS

OUTPUT

DEBUG CONSOLE

TERMINAL

PORTS

GITLENS

AZURE

pwsh

(.venv) PS C:\Users\yafit\Documents\GitHub\20940_maman_16_end> python run_combinations.py

[Brute-Force] Attacking user: user11

[+] Password found for user11: Password11!

[+] Experiment sha256_pepper completed.

=== Running experiment: sha256_lockout ===

[*] Launching attacker for sha256_lockout...

[Brute-Force] Attacking user: user11

[+] Password found for user11: Password11!

[+] Experiment sha256_lockout completed.

=== Running experiment: sha256_captcha ===

[*] Launching attacker for sha256_captcha...

[Brute-Force + CAPTCHA] Attacking user: user11

[+] Password found for user11: Password11!

[+] Experiment sha256_captcha completed.

=== Running experiment: sha256_rate_limit ===

[*] Launching attacker for sha256_rate_limit...

[Brute-Force] Attacking user: user11

[+] Password found for user11: Password11!

[+] Experiment sha256_rate_limit completed.

main*

Launchpad

0 0

You, 2 hours ago

Yafit (2 hours ago)

Ln 110, Col 1 (26 selected)

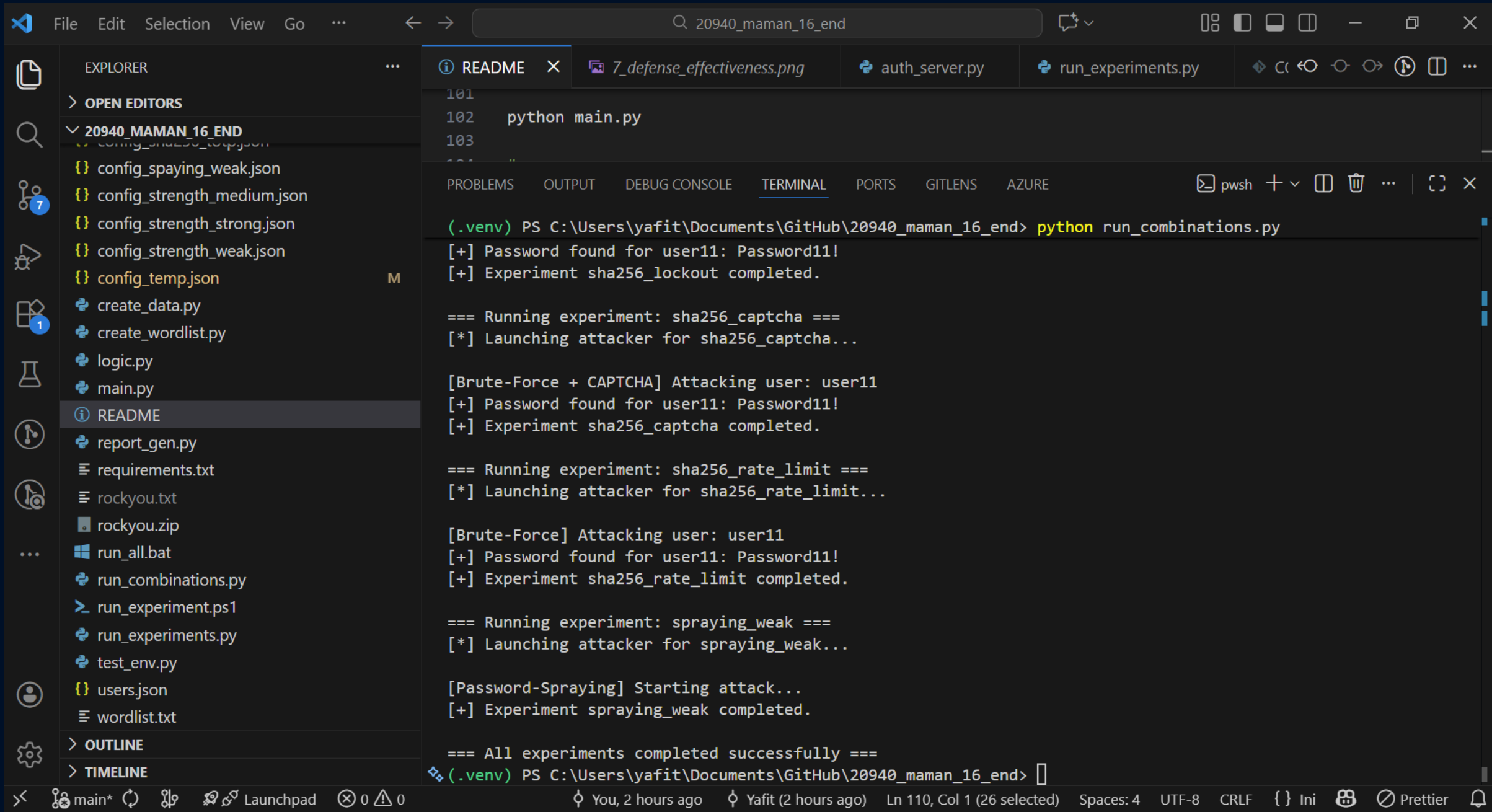
Spaces: 4

UTF-8

CRLF

{ } Ini

Prettier



FileEditSelectionViewGo

20940_maman_16_end

7_defense_effectiveness.pngauth_server.pyrun_experiments.py

EXPLORER

OPEN EDITORS

20940_MAMAN_16_END

config_spraying_weak.json

config_strength_medium.json

config_strength_strong.json

config_strength_weak.json

config_temp.json

create_data.py

create_wordlist.py

logic.py

main.py

README

report_gen.py

requirements.txt

rockyou.txt

rockyou.zip

run_all.bat

run_combinations.py

run_experiment.ps1

run_experiments.py

test_env.py

users.json

wordlist.txt

OUTLINE

TIMELINE

101

102python main.py

PROBLEMS

OUTPUT

DEBUG CONSOLE

TERMINAL

PORTS

GIT LENS

AZURE

python

[Brute-Force] Attacking user: user11

[+] Password found for user11: Password11!

[+] Experiment sha256_rate_limit completed.

=== Running experiment: spraying_weak === ...

[+] Experiment spraying_weak completed.

=== All experiments completed successfully ===

(.venv) PS C:\Users\yafit\Documents\GitHub\20940_maman_16_end> python run_experiments.py

=== Running experiment: no_protection ===

Running attacker...

[Brute-Force] Attacking user: user11

[+] Password found for user11: Password11!

Experiment no_protection completed.

=== Running experiment: with_protection ===

Running attacker...

[Brute-Force + CAPTCHA] Attacking user: user11

[+] Password found for user11: Password11!

Experiment with_protection completed.

=== Running experiment: bcrypt ===

Running attacker...

[Brute-Force] Attacking user: user11

main*

Launchpad

You, 2 hours ago

Yafit (2 hours ago)

Ln 112, Col 1 (25 selected)

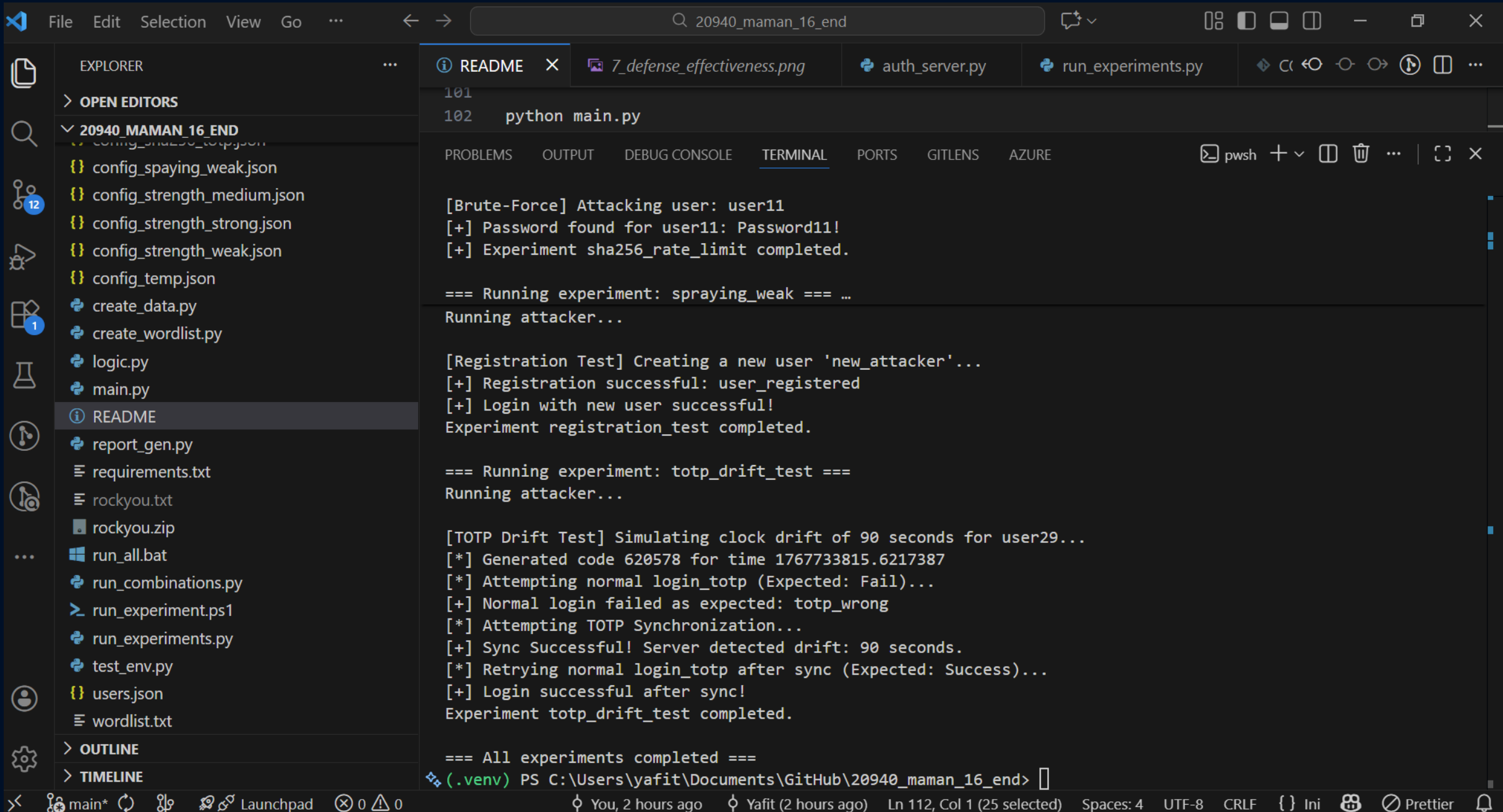
Spaces: 4

UTF-8

CRLF

{ } Ini

Prettier



FileEditSelectionViewGo

20940_maman_16_end

7_defense_effectiveness.pngauth_server.pyrun_experiments.py

EXPLORER

OPEN EDITORS

20940_MAMAN_16_END

logs

attempts_registration_test.logattempts_sha256_captcha.logattempts_sha256_lockout.logattempts_sha256_pepper.logattempts_sha256_rate_limit.logattempts_sha256_salt.logattempts_spraying_weak.logattempts_totp_drift_test.logattempts_with_protection.log

output\graphs

1_attempts_per_experiment.png5_attack_progression.png.gitignoreanalyze.pyattacker.pyauth_server.pycommon_passwords.txtconfig_all.jsonconfig_argon2id_full_protection.jsonconfig_argon2id_no_protection.json

OUTLINE

TIMELINE

README

python run_experiments.py

python analyze.py

python main.py

OR simply run the batch file:

.\run_all.bat

PROBLEMS

OUTPUT

DEBUG CONSOLE

TERMINAL

PORTS

GITLENS

AZURE

pwsh

[Registration Test] Creating a new user 'new_attacker'...

[Registration Test] Creating a new user 'new_attacker'...

[+] Registration successful: user_registered

[+] Registration successful: user_registered

[+] Login with new user successful! ...

[+] Login successful after sync!

Experiment totp_drift_test completed.

=== All experiments completed ===

(.venv) PS C:\Users\yafit\Documents\GitHub\20940_maman_16_end> python analyze.py

--- Starting Analysis on logs ---

[*] Analyzing logs in: logs

[+] Fixed Graph 5 generated (filtered view).

--- Analysis Logic Complete ---

(.venv) PS C:\Users\yafit\Documents\GitHub\20940_maman_16_end>

main*

Launchpad

You, 1 hour ago

Yafit (1 hour ago)

Ln 116, Col 1 (14 selected)

Spaces: 4

UTF-8

CRLF

{ } Ini

Prettier

FileEditSelectionViewGo

20940_maman_16_end

20940_maman_16_end

auth_server.pyrun_experiments.py

EXPLORER

OPEN EDITORS

20940_MAMAN_16_END

logs

attempts_registration_test.logattempts_sha256_captcha.logattempts_sha256_lockout.logattempts_sha256_pepper.logattempts_sha256_rate_limit.logattempts_sha256_salt.logattempts_spraying_weak.logattempts_totp_drift_test.logattempts_with_protection.log

output

graphs

1_attempts_per_experiment.png2_success_rate.png3_hashing_speed.png4_failure_reasons.png5_attack_progression.png6_latency_comparison.png7_defense_effectiveness.pnganalysis_report.html.gitignore

OUTLINE

TIMELINE

README

7_defense_effectiveness.png

python analyze.py

python main.py

#=====

OR simply run the batch file:

.\run_all.bat

python analyze.py

PROBLEMS

OUTPUT

DEBUG CONSOLE

TERMINAL

PORTS

GITLENS

AZURE

pwsh

[+] Registration successful: user_registered

[+] Registration successful: user_registered

[+] Login with new user successful! ...

(.venv) PS C:\Users\yafit\Documents\GitHub\20940_maman_16_end> python main.py

--- Starting Auth Analysis Automation ---

--- Starting Analysis on logs ---

[*] Analyzing logs in: logs

[+] Loaded 868 total log entries.

[*] Saving graphs to: output\graphs

[+] Generated graph: 2_success_rate.png

Generating summary graphs for conclusions...

[+] Generated graph: 6_latency_comparison.png

Generating full report...

[*] Generating HTML report in: output

[+] Report generated successfully: output\analysis_report.html

--- Analysis Logic Complete ---

--- Process Completed Successfully ---

Check the 'output' directory for your report.

(.venv) PS C:\Users\yafit\Documents\GitHub\20940_maman_16_end>

main*

Launchpad

0 0

You, 1 hour ago

Yafit (1 hour ago)

Ln 116, Col 1 (14 selected)

Spaces: 4

UTF-8

CRLF

{ } Ini

Prettier

לפני ביצוע הרצה מלאה חדשה מומלץ למחוק או להעביר
את התיקיות של הלוגים והגרפים מההרצה הקודמת
/output
& /logs
על מנת למנוע שגיאות סטטיסטיות וגרפיות.

Run 2

```
.\run_all.bat  
python analyze.py  
python main.py
```

File

Edit

Selection

View

Go

...

←

→

Q

20940_maman_16_end

EXPLORER

...

> OPEN EDITORS

> 20940_MAMAN_16_END

config_strength_medium.json

config_strength_strong.json

config_strength_weak.json

config_temp.json

create_data.py

create_wordlist.py

logic.py

main.py

README

report_gen.py

requirements.txt

rockyou.txt

rockyou.zip

run_all.bat

run_combinations.py

run_experiment.ps1

run_experiments.py

test_env.py

users.json

wordlist.txt

> OUTLINE

> TIMELINE

README

auth_server.py

run_experiments.py

COMMIT_EDITMSG

logic.py

116

python main.py

117

118

=====

119

OR simply run the batch file:

120

121

.\run_all.bat

122

123

python analyze.py

124

125

python main.py

You, 2 hours ago • .

PROBLEMS

OUTPUT

DEBUG CONSOLE

TERMINAL

PORTS

GITLENS

AZURE

pwsh

+

+

...

[]

X

● PS C:\Users\yafit\Documents\GitHub\20940_maman_16_end> & C:/Users/yafit/Documents/GitHub/20940_maman_16_end/.venv/Scripts/Activate.ps1

○ (.venv) PS C:\Users\yafit\Documents\GitHub\20940_maman_16_end>

<

>

main

Launchpad

0

0

You, 2 hours ago

Yafit (2 hours ago)

Ln 125, Col 1 (14 selected)

Spaces: 4

UTF-8

CRLF

{ }

Ini

Prettier

20940_maman_16_...

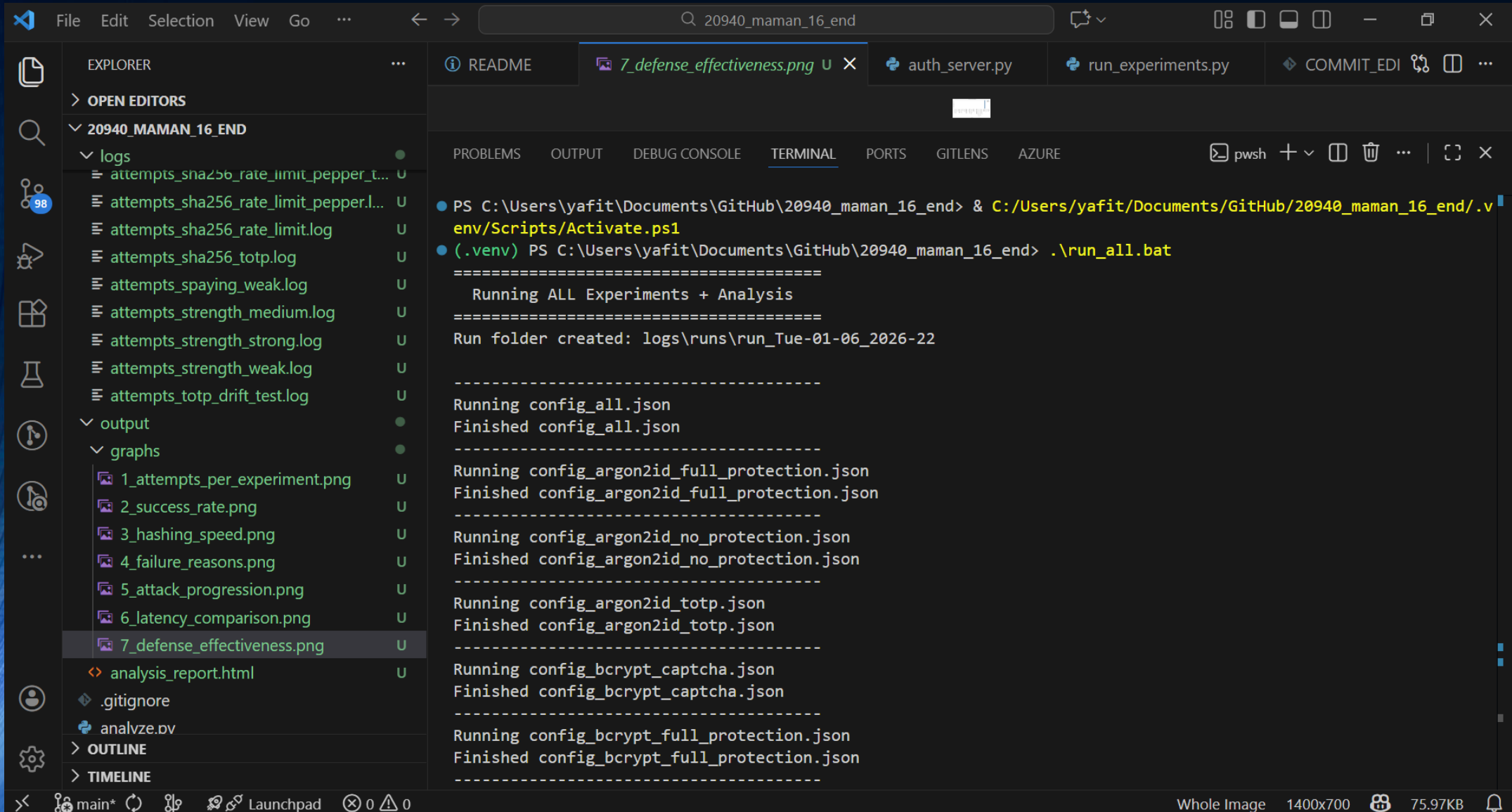
README - 20940_m...

ShareX 18.0.1

10:46 PM

1/6/2026

run2



File

Edit

Selection

View

Go

...

←

→

20940_maman_16_end

7_defense_effectiveness.png

auth_server.py

run_experiments.py

COMMIT_EDIT

7_defense_effectiveness.png

auth_server.py

run_experiments.py

COMMIT_EDIT

20940_MAMAN_16_END

logs

attempts_sha256_rate_limit_pepper.t...

attempts_sha256_rate_limit_pepper.l...

attempts_sha256_rate_limit.log

attempts_sha256_totp.log

attempts_spaying_weak.log

attempts_strength_medium.log

attempts_strength_strong.log

attempts_strength_weak.log

attempts_totp_drift_test.log

output

graphs

1_attempts_per_experiment.png

2_success_rate.png

3_hashing_speed.png

4_failure_reasons.png

5_attack_progression.png

6_latency_comparison.png

7_defense_effectiveness.png

analysis_report.html

.gitignore

analvze.py

PROBLEMS

OUTPUT

DEBUG CONSOLE

TERMINAL

PORTS

GITLENS

AZURE

(.venv) PS C:\Users\yafit\Documents\GitHub\20940_maman_16_end> .\run_all.bat

Running config_temp.json

Finished config_temp.json

Running analysis...

--- Starting Analysis on logs ---

[*] Analyzing logs in: logs

--- Analysis Logic Complete ---

All experiments completed

Analysis finished

PDF report saved at:

logs\runs\run_Tue-01-06_2026-22\analysis_report.pdf

Graphs and logs saved in:

logs\runs\run_Tue-01-06_2026-22

Moving attempts*.log files into run folder (if any)...

attempts*.log files moved to logs\runs\run_Tue-01-06_2026-22.

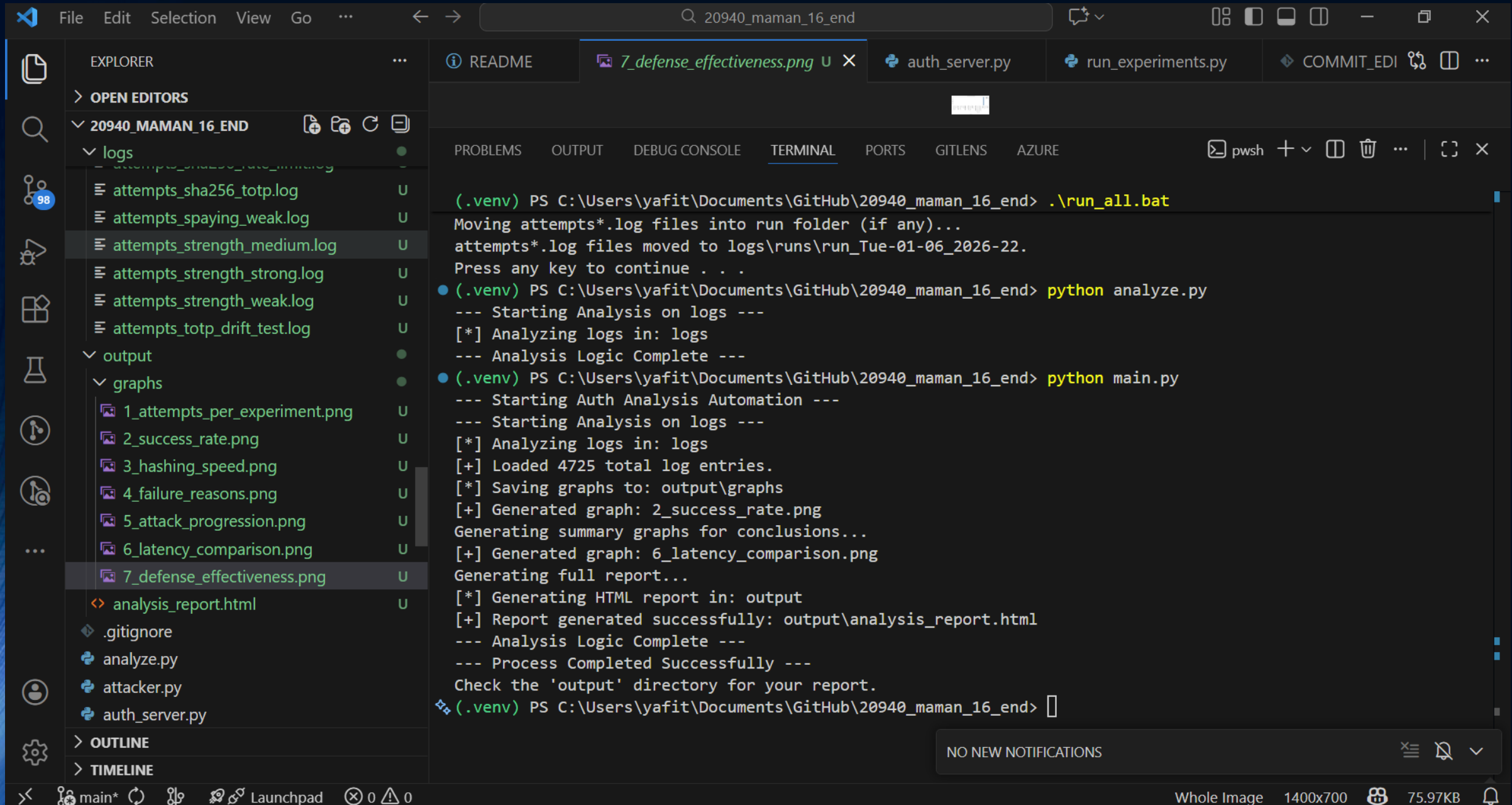
Press any key to continue . . .

(.venv) PS C:\Users\yafit\Documents\GitHub\20940_maman_16_end> python analyze.py

--- Starting Analysis on logs ---

[*] Analyzing logs in: logs

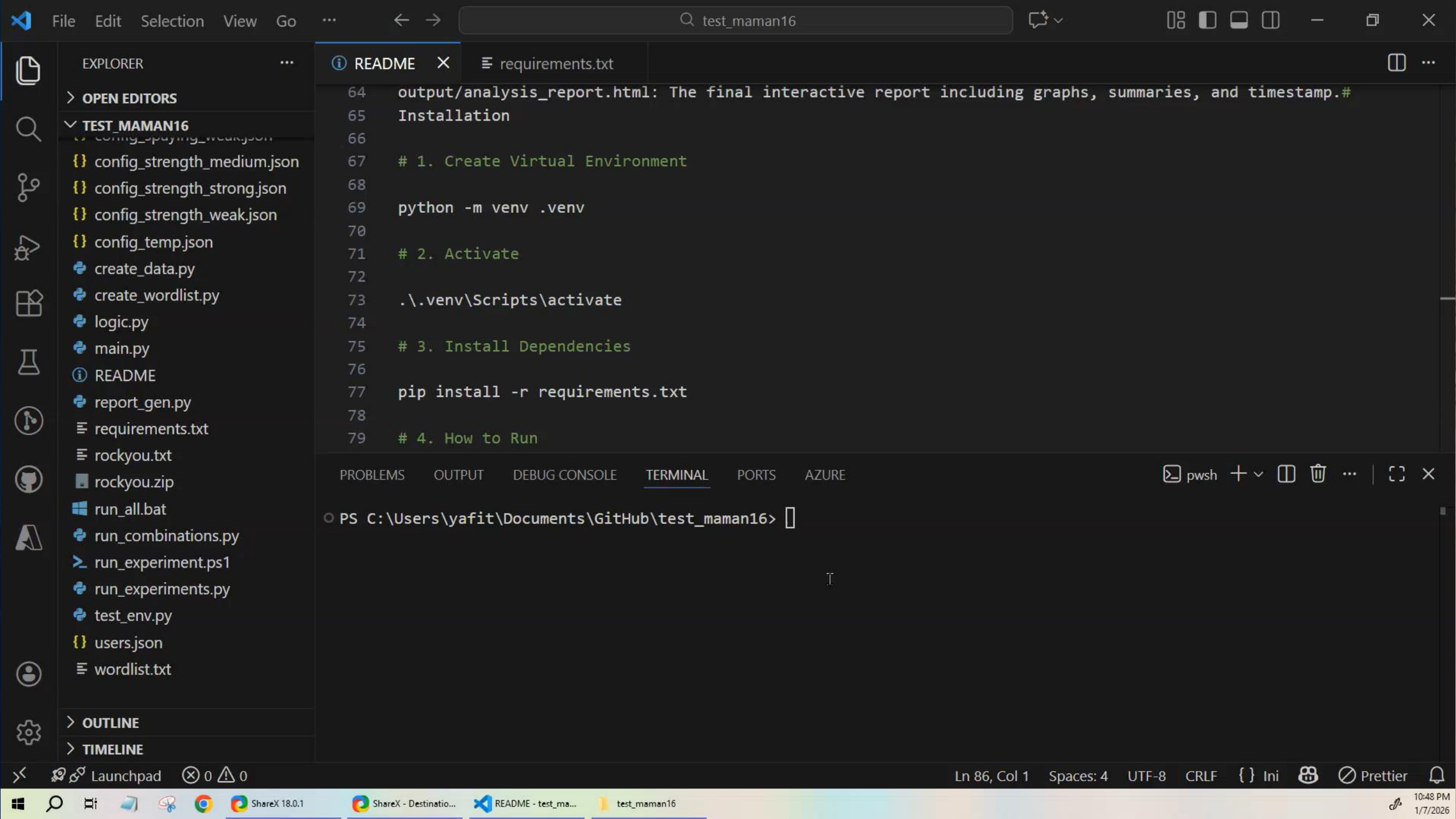
NO NEW NOTIFICATIONS



Run3 = run1+run2+Create Virtual Environment + Install Dependencies

- 1. Create Virtual Environment
- `python -m venv .venv`
- # 2. Activate
- `.\.venv\Scripts\activate`
- # 3. Install Dependencies
- `pip install -r requirements.txt`
- # 1. For a complete run from scratch, execute these commands in order:
- `python create_wordlist.py`
- `python run_combinations.py`
- `python run_experiments.py`
- `python analyze.py`
`python main.py`

- # Before performing a new full run, it is recommended to delete or move the logs and graphs folders
- # from the previous run to /output & /logs in order to prevent statistical and graphical errors.
- # 2. OR simply run the batch file:
- .\run_all.bat
- python analyze.py
- python main.py



תודה רבה! 😊